

Narrativa explicativa de la Encuesta TLPT

1. Por qué esta encuesta y por qué ahora

DORA ha elevado las pruebas TLPT a la categoría de “deber cívico” de las entidades financieras con capacidad de generar impacto sistémico.[web:16][web:39]

TIBER-ES ha aterrizado este deber en España con un marco operativo detallado que ya no deja mucho espacio a la improvisación heroica.[web:38]

Esta encuesta no pretende ser un examen, sino un espejo; uno que, eso sí, devuelve imágenes de alta resolución sobre gobierno, alcance, metodología y cultura de ciberresiliencia.

La ironía en algunas opciones de respuesta no busca ridiculizar, sino aliviar la digestión de lo que, en el fondo, es un ejercicio muy serio.

2. De la “prueba técnica” al “test de resiliencia”

Durante años, muchas organizaciones han llamado “test de intrusión” a ejercicios limitados que nunca ejercitaban la cadena completa de valor ni ponían en jaque los procesos de negocio.

TLPT, en cambio, exige pruebas basadas en amenazas reales, sobre sistemas en producción, con participación de funciones críticas y terceros TIC.[web:36][web:39]

La encuesta refleja ese cambio de paradigma:

- Preguntas sobre funciones críticas, no solo sobre sistemas.
- Preguntas sobre proveedores TIC en alcance, no como nota a pie de página.
- Preguntas sobre MTDD/MTTR y remediación, no solo sobre el número de hallazgos.

3. Qué busca cada bloque

- Gobierno y alineamiento normativo: identificar si TLPT está anclado en políticas, comités y decisiones formales, o si sigue siendo un proyecto “experimental”. [web:16]
- Alcance y criticidad: medir cuánto del mapa real de riesgo (funciones, terceros, geografía) entra de verdad en el tanque de pruebas. [web:39]
- Metodología TTI + Red Team: distinguir entre un pentest sofisticado y un TLPT genuino alimentado por inteligencia de amenazas.
- Detección, respuesta y continuidad: evaluar reflejos y músculo operacional, no solo capacidades tecnológicas.
- Remediación y attestation: pasar del “qué mal estamos” al “qué hacemos al respecto y cómo lo demostramos al supervisor”. [web:16]
- Madurez cultural: entender si TLPT se percibe como amenaza burocrática o como aliado estratégico.

4. Cómo leer los resultados con espíritu constructivo

Un resultado bajo en IGM no debería provocar vergüenza, sino curiosidad: ¿qué parte del ciclo (gobierno, alcance, operaciones, remediación) nos frena más?

Las comparaciones con pares sectoriales sirven para contextualizar, no para buscar culpables.

Lo que realmente importa es la trayectoria: una entidad que arranca con un nivel modesto pero usa los resultados para reorientar inversiones y procesos supera, en la práctica, a quien declara altos niveles de madurez pero no cambia nada.

5. La ironía como mecanismo de defensa (y de aprendizaje)

Las opciones de respuesta, a veces deliberadamente irónicas, cumplen tres funciones:

1. Desactivar la tentación de contestar de forma “perfecta” sin reflejar la realidad.
2. Invitar a la reflexión (“¿de verdad nuestro TLPT fue solo un pentest glamurizado?”).
3. Facilitar que, en un taller, los distintos actores (CISO, CIO, COO, riesgos, negocio) hablen con más franqueza.

Si al leer una opción el responsable de la entidad sonríe con complicidad, probablemente hemos acertado la diana del problema.

6. Próximos pasos sugeridos

- Utilizar la encuesta antes del siguiente TLPT para priorizar alcance y escenarios.
- Repetirla después para medir impacto y ajustar el plan de acción.
- Combinar sus resultados con indicadores cuantitativos (incidentes, pérdidas, sanciones, auditorías) para calcular el retorno de la resiliencia más allá del simple ROI contable.

La encuesta no decide por sí sola qué hay que hacer, pero ayuda a poner las preguntas incómodas en la agenda correcta.